Information Security Policy

Northwind Cloud Ltd. - Internal - Version 3.2 - Effective 2026-07-01

1. Purpose and scope

This policy defines the minimum security controls for all Northwind Cloud production and staging systems, employees and contractors. Exceptions require written approval from the CISO and must be recorded in the risk register with an expiry date no longer than 90 days.

2. Data classification

Data is classified as Public, Internal, Confidential or Restricted. Restricted data includes cardholder data, authentication secrets and customer PII. Restricted data must be encrypted at rest with AES-256 and in transit with TLS 1.2 or higher, and must never be stored in source code repositories, tickets or chat tools.

3. Access control and MFA

Access follows least privilege and is reviewed quarterly by the system owner. All workforce accounts require multi-factor authentication. Privileged and administrator accounts must use phishing-resistant MFA (FIDO2 hardware security keys); SMS and voice one-time codes are not permitted for administrators. Shared accounts are prohibited. Access for leavers must be revoked within 4 hours of HR notification.

4. Vulnerability management

All production hosts are scanned weekly. Findings must be remediated within the following SLAs, measured from first detection:

- Critical (CVSS 9.0-10.0): 7 calendar days. Internet-facing systems: 72 hours.
- High (CVSS 7.0-8.9): 30 calendar days.
- Medium (CVSS 4.0-6.9): 90 calendar days.
- Low (CVSS 0.1-3.9): 180 calendar days or next scheduled maintenance.

Vulnerabilities listed in the CISA Known Exploited Vulnerabilities (KEV) catalogue are treated as Critical regardless of CVSS score. Findings that breach SLA are escalated to the owning team's engineering manager and reported in the monthly security review.

5. Logging and monitoring

Security-relevant logs (authentication, privilege changes, network flow, cloud audit trails) are forwarded to the SIEM. Log retention is 365 days in the SIEM and 7 years in cold storage for systems in PCI scope. SIEM alerts of severity High or Critical must be triaged within 30 minutes by the on-call SOC analyst.

6. Secrets management

Secrets (API keys, passwords, tokens, private keys) must be stored in the central vault. Any secret found in a repository, log, ticket or chat must be treated as compromised: it must be revoked and rotated within 1 hour and the exposure investigated per the leaked-credential runbook.

7. Incident severity levels

SEV1 - Customer-facing outage or confirmed data breach. Incident Commander paged immediately; executive update within 30 minutes.

SEV2 - Major degradation or contained security incident. Response within 15 minutes.

SEV3 - Minor degradation with workaround available. Response within 4 business hours.

SEV4 - Cosmetic or no customer impact. Handled through the normal backlog.